TFG · SONDA PASIVA DE DETECCIÓN PQC

Campaña de medidas sobre servidores reales

Estado de la adopción de criptografía postcuántica en 20 dominios españoles e internacionales

Pablo Marugán Bastante · GITST, EPS-UAM · Tutor: Jorge E. López de Vergara | **Medidas del 12/10/2026** | Tutoría del miércoles 14/10/2026

1. Metodología

Las medidas se han tomado con `sonda_tls.py`, una herramienta auxiliar escrita para este TFG que construye mensajes `ClientHello` de TLS 1.3 byte a byte y parsea la respuesta. No usa OpenSSL ni ninguna biblioteca TLS: implementa el protocolo directamente, que es lo que permite controlar con precisión qué se le ofrece a cada servidor.

Esta herramienta **no es el TFG**, que es una sonda pasiva escrita en C. Es andamiaje: genera vectores de prueba y permite validar contra servidores reales el algoritmo de análisis que después se porta a C.

Las cuatro pruebas por servidor

Prueba	Qué se ofrece	Qué permite determinar
Versión	TLS 1.2 y 1.3 simultáneamente	Si el servidor habla TLS 1.3. Sin TLS 1.3 no existe PQC.
A	PQC en `supported_groups`, `key_share` solo clásico	La política del servidor ante un cliente que no gasta 1,2 kB en claves
B	Cliente puramente clásico	Control negativo
C	PQC en `supported_groups` y `key_share` postcuántico	La capacidad real del servidor, sin ambigüedad

La clave del diseño está en separar A de C: **el caso C pone la clave postcuántica en manos del servidor sin coste adicional de latencia**. Si aun así elige un grupo clásico, lo está rechazando deliberadamente.

2. Resultados

11 / 20
Servidores con intercambio de claves postcuántico

4 / 20
Sin TLS 1.3: incapaces de PQC por diseño

45 %
De los capaces, los que NO fuerzan PQC con HelloRetryRequest

Dominio	Sector	Veredicto	Motivo
www.google.com	Tecnología	**SEGURO**	X25519MLKEM768, fuerza con HelloRetryRequest
www.wikipedia.org	Tecnología	**SEGURO**	X25519MLKEM768, fuerza con HelloRetryRequest
www.amazon.es	Tecnología	**SEGURO**	X25519MLKEM768, fuerza con HelloRetryRequest
www.caixabank.es	Banca	**SEGURO**	X25519MLKEM768, fuerza con HelloRetryRequest
sede.administracion.gob.es	Administración	**SEGURO**	X25519MLKEM768, fuerza con HelloRetryRequest
www.correos.es	Servicios	**SEGURO**	X25519MLKEM768, fuerza con HelloRetryRequest

Dominio	Sector	Veredicto	Motivo
www.bbva.es	Banca	SEGURO	**Soporta PQC pero no lo fuerza**
www.ing.es	Banca	SEGURO	**Soporta PQC pero no lo fuerza**
www.seg-social.es	Administración	SEGURO	**Soporta PQC pero no lo fuerza**
www.renfe.com	Servicios	SEGURO	**Soporta PQC pero no lo fuerza**
www.idealista.com	Servicios	SEGURO	**Soporta PQC pero no lo fuerza**
www.santander.es	Banca	INSEGURO	TLS 1.3, rechaza el key_share postcuántico ofrecido
www.boe.es	Administración	INSEGURO	TLS 1.3, rechaza el key_share postcuántico ofrecido
www.uam.es	Universidad	INSEGURO	TLS 1.3, rechaza el key_share postcuántico ofrecido
www.upm.es	Universidad	INSEGURO	TLS 1.3, rechaza el key_share postcuántico ofrecido
www.ucm.es	Universidad	INSEGURO	TLS 1.3, rechaza el key_share postcuántico ofrecido
www.elpais.com	Prensa	INSEGURO	**Sin TLS 1.3** (negocia TLS 1.2)
www.sabadell.com	Banca	INSEGURO	**Sin TLS 1.3** (negocia TLS 1.2)
www.uc3m.es	Universidad	INSEGURO	**Sin TLS 1.3** (negocia TLS 1.2)
www.movistar.es	Servicios	INSEGURO	**Sin TLS 1.3** (negocia TLS 1.2)

Por sectores

Sector	Con PQC	Comentario
Tecnología	3 / 3	Google, Wikipedia y Amazon. Todos fuerzan PQC activamente.
Banca	3 / 5	CaixaBank, BBVA e ING sí. Santander no. Sabadell ni siquiera tiene TLS 1.3.
Administración	2 / 3	La Sede Electrónica y la Seguridad Social sí; el BOE no.
Servicios	3 / 5	Correos, Renfe e Idealista sí. Movistar sin TLS 1.3.
Universidad	0 / 4	**Ninguna.** UAM, UPM y UCM en TLS 1.3 sin PQC; la UC3M sin TLS 1.3.

El contraste es nítido: el sector tecnológico ha completado la migración, la banca y la administración van a dos velocidades, y **el sector universitario no ha empezado**.

3. El hallazgo principal: la política del servidor es invisible desde fuera

De los 11 servidores capaces de postcuántico, conviven **dos políticas opuestas** ante el mismo ClientHello:

Política	N°	Servidores
Fuerza PQC Responde HelloRetryRequest y gasta un RTT adicional	6	Google, Wikipedia, Amazon, CaixaBank, Sede Electrónica, Correos
No lo fuerza Se conforma con el grupo clásico que ya tiene	5	BBVA, ING, Seguridad Social, Renfe, Idealista

> **CONSECUENCIA PARA LA SONDA PASIVA: 45 % DE FALSOS NEGATIVOS**
>
> Si la sonda observa una conexión en la que el cliente anunció grupos postcuánticos en `supported_groups` pero no envió `key_share` postcuántico, y concluye «inseguro» al ver que el servidor eligió un grupo clásico, **se equivocaría en 5 de los 11 servidores capaces**. El servidor soporta PQC perfectamente; simplemente está evitando el coste de latencia del HelloRetryRequest.

Esta es la diferencia esencial entre la sonda activa y la pasiva. En modo activo se controla el ClientHello y se puede forzar el caso C, que es concluyente. **En modo pasivo se observa lo que haya**, y lo que haya depende de qué cliente intervenga.

De aquí salen tres decisiones de diseño, todas respaldadas por estas medidas:

- **«Indeterminado» tiene que ser un estado de primera clase**, nunca un sinónimo de «inseguro». La tasa de error de no hacerlo está medida: 45 %.
- **Hay que guardar el `key_share` del cliente junto con la elección del servidor**, no solo la elección. Sin saber qué tenía disponible el servidor al elegir, el veredicto no es interpretable.
- **Hace falta estado persistente por servidor**, no solo por conexión. Un servidor observado muchas veces acabará siendo clasificable aunque ninguna conexión individual lo sea.

4. Dos hallazgos secundarios

4.1. Sin TLS 1.3 no hay postcuántico posible

Cuatro de los veinte dominios negocian TLS 1.2 y no ofrecen TLS 1.3 en absoluto. Los tres grupos híbridos de la RFC 10024 están definidos **únicamente para TLS 1.3**, de modo que estos servidores no es que estén mal configurados: **no pueden** hacer intercambio de claves postcuántico sin actualizar antes la versión del protocolo.

Esto obliga a distinguir **dos categorías de inseguridad**, con remediaciones muy distintas:

Categoría	N°	Remediación
TLS 1.3 sin PQC	5	Cambio de configuración, posiblemente actualización de la biblioteca TLS
Sin TLS 1.3	4	Migración de versión de protocolo: mucho más costosa

Para la sonda es una comprobación barata: **si el ServerHello no trae la extensión `supported_versions` (43), lo negociado es TLS 1.2 o anterior**, y se clasifica como inseguro sin necesidad de analizar `key_share` — que en TLS 1.2 ni siquiera existe.

4.2. Un ServerHello sin extensiones hace caer un parser ingenuo

`www.sabadell.com` devuelve un ServerHello que **termina justo después del método de compresión**, sin bloque de extensiones. En TLS 1.2 ese campo es opcional; en TLS 1.3 es obligatorio.

> **AVISO DE IMPLEMENTACIÓN**
>
> El parser de la herramienta falló con este servidor por asumir que el bloque de extensiones siempre está presente. En Python eso es una excepción; **en C sería una lectura fuera de buffer**, es decir, una vulnerabilidad en un programa que procesa tráfico de red no confiable. La sonda debe comprobar los límites **en cada lectura**, no solo al principio de cada capa.

5. Limitaciones de estas medidas

- **Muestra pequeña y no aleatoria.** Veinte dominios elegidos por sectores de interés, no un muestreo estadístico. Sirven para ilustrar fenómenos, no para estimar porcentajes de adopción nacionales.
- **Una sola observación por servidor y momento.** No se ha comprobado estabilidad temporal ni comportamiento entre distintos nodos de un mismo CDN.
- **Modo activo.** Estas medidas son del tipo que hace el TFG de Roberto Sanz. Su valor aquí es validar el analizador de protocolo y cuantificar el problema que motiva el diseño de la sonda pasiva.
- **El ClientHello de la herramienta es mínimo** y no reproduce la huella de un navegador real. Cualquier servidor que discrimine por huella TLS podría responder de forma distinta a un navegador. La sonda pasiva, al observar navegadores reales, no tiene

esta limitación.

6. Qué llevar a la tutoría

Punto	Dato que lo respalda
La adopción ha avanzado mucho desde enero de 2026	11 de 20, incluidos tres bancos y dos sedes de la administración
El estado «indeterminado» es imprescindible	45 % de falsos negativos medidos sobre los servidores capaces
Hay que detectar la versión antes que nada	4 de 20 no tienen TLS 1.3 y por tanto no pueden tener PQC
Dos categorías de inseguridad, no una	5 por configuración, 4 por versión de protocolo
La robustez del parser no es opcional	www.sabadell.com rompe un parser que no comprueba límites
Ninguna universidad española medida soporta PQC	UAM, UPM, UCM y UC3M: 0 de 4